

Assignment 5

Low-Level Technical Report on REvil (Sodinokibi) Ransomware

1. Overview of REvil (Sodinokibi) Ransomware:-

REvil (Sodinokibi) is a notorious strain of ransomware that first appeared in 2019. It is known for its **double extortion** tactics, where not only does the ransomware encrypt files, but it also **steals sensitive data** from the victim's system. The attackers then demand a ransom for both decrypting the files and not releasing the stolen data.

This ransomware has affected a wide range of industries, including IT companies, healthcare, and manufacturing. It is often distributed by **affiliate hackers** who use methods such as phishing, RDP (Remote Desktop Protocol) brute-forcing, and exploiting vulnerabilities in outdated software.

2. Exploitation Methods Used by REvil Ransomware

REvil typically exploits several **vectors** to gain initial access to a target system. These include:

a) Phishing Emails:

Phishing emails are often the **first step** in distributing REvil. These emails may contain malicious attachments or links that, when opened, execute the ransomware. For example, the email could contain an **infected document** with macros that, when opened, download the ransomware onto the victim's system.

b) RDP Brute-Force Attacks:

Another method REvil uses is exploiting weak or compromised **RDP credentials**. Many organizations leave **RDP open to the internet** with weak passwords, making it a popular attack vector for cybercriminals. Once they gain access via brute-forcing RDP credentials, they deploy the ransomware.

c) Exploiting Vulnerabilities:

REvil also exploits **unpatched vulnerabilities** in software or network services. For example, it could take advantage of vulnerabilities in **VPNs, Windows SMB (Server Message Block),** or **unsecured web servers** to gain access to a system. Once inside, it spreads across the network and executes the ransomware payload.

3. Encryption Mechanism Used by REvil Ransomware

Once REvil gains access to a victim's system, it begins its **encryption process**. The ransomware typically uses the following:

a) AES-256 Encryption (Symmetric Encryption):

REvil encrypts files using **AES-256**, which is a **symmetric encryption algorithm**. This means that the same key is used to encrypt and decrypt the files. AES-256 is strong and widely used in modern encryption systems, which makes it difficult for attackers to break without the decryption key.

b) RSA Encryption (Asymmetric Encryption):

To protect the decryption key, REvil also uses **RSA encryption**, a form of **asymmetric encryption**. In RSA, there are two keys: a **public key** (for encryption) and a **private key** (for decryption). The public key is used to encrypt the files, while the private key (which only the attacker has) is needed to decrypt them. When REvil encrypts files, the private decryption key is stored on the **attacker's server**. If the victim pays the ransom, they are supposed to receive the private key to decrypt their files.

4. Lateral Movement by REvil Ransomware

Once the initial infection occurs, REvil spreads across the network. This **lateral movement** helps it infect other systems in the organization. The main techniques REvil uses to move laterally include:

a) Exploiting Shared Network Drives:

REvil can search for **network shares** or mapped drives that are accessible by the infected system. It then spreads the

ransomware to these shared drives, encrypting other systems in the network.

b) Privilege Escalation:

REvil may use **privilege escalation techniques** to gain higher-level access on a compromised system. This allows it to execute commands with **administrator** or **root privileges**, helping it to deploy and spread the ransomware more effectively.

c) RDP and VPN Exploits:

If the attacker gains access via **RDP** or **VPN**, they can **pivot** and move deeper into the network. Once inside the network, the ransomware will attempt to infect all connected systems and devices.

5. Cyber Attack Kill Chain for REvil

The **Cyber Attack Kill Chain** is a model that describes the stages of a cyber attack, from initial reconnaissance to the final stage (the attacker's objective). Here's how REvil fits into the Kill Chain:

a) Reconnaissance (Stage 1):

- **Attackers gather information** about the target, typically through scanning the internet for open **RDP ports** or other vulnerable services.
- They may also conduct **phishing campaigns** to gather emails or exploit publicly available data about the organization.

b) Weaponization (Stage 2):

- The attackers create the **malicious payload** (REvil ransomware) and integrate it with **phishing emails** or **exploit kits** to gain access to the target system.
- They may also use **malicious links** or **attachments** to infect the victim's machine.

c) Delivery (Stage 3):

- REvil is delivered via **phishing emails** with malicious attachments or links.
- Alternatively, attackers can use **RDP brute-force** to gain access directly.

d) Exploitation (Stage 4):

- Once the malicious link or attachment is clicked, **REvil is executed** on the victim's system. It exploits any **security vulnerabilities** and starts encrypting files.
- In some cases, REvil exploits **unpatched vulnerabilities** in software or operating systems.

e) Installation (Stage 5):

- REvil is installed on the system and starts the encryption process.
- It installs itself as a **persistent** malware, ensuring that it runs even after a system restart.

f) Command and Control (C2) Communication (Stage 6):

- REvil connects to the **attacker's server** to send encrypted data and receive decryption keys.
- It can communicate with the **attacker's infrastructure** to deliver ransom demands and report encrypted files.

g) Action on Objectives (Stage 7):

- **Encryption of files:** REvil encrypts sensitive files on the victim's system.
- **Double Extortion:** It steals data and threatens to release it unless the ransom is paid.
- **Ransom Demand:** The attackers demand a ransom, usually in cryptocurrency like Bitcoin, to provide the decryption key and not release stolen data.

6. Mitigation Strategies for REvil Ransomware

To prevent or minimize the impact of REvil ransomware, the following mitigation strategies are recommended:

a) Strong Authentication:

- Implement **multi-factor authentication (MFA)** for all critical systems, especially RDP and VPN.
- Use strong passwords for RDP access, and disable RDP if not necessary.

b) Patch and Update Systems:

- Regularly **patch and update** all software, including operating systems and applications, to prevent exploitation of known vulnerabilities.
 - Apply patches for vulnerabilities like **EternalBlue**, which has been used by other ransomware strains.
- c) Network Segmentation:
- **Segment the network** to limit lateral movement. Sensitive systems should be isolated from others.
 - Implement **network segmentation** to prevent ransomware from spreading throughout the network.
- d) Backup and Recovery:
- Regularly back up critical data and store it in **offline** or **cloud-based** systems that are not connected to the internal network.
 - Ensure **backups** are also encrypted and regularly tested for integrity
- e) Security Awareness and Training:
- Educate employees about the dangers of **phishing emails** and **malicious attachments**. Encourage them to verify suspicious emails and links.
 - Conduct regular **security training** and **phishing simulation exercises**.
- f) Use of Endpoint Detection and Response (EDR):
- Deploy **EDR** tools to monitor and block malicious activities in real-time. These tools can detect **file encryption patterns** and alert security teams to ransomware attacks.

7. Conclusion

REvil (Sodinokibi) ransomware is a highly destructive malware that uses sophisticated techniques to infect networks, encrypt files, and steal sensitive data. By exploiting weaknesses like unpatched software, weak passwords, and phishing emails, REvil can quickly spread across an organization's network.

Implementing strong security practices such as multi-factor

authentication, regular software patching, network segmentation, and employee training can greatly reduce the risk of a REvil attack.